



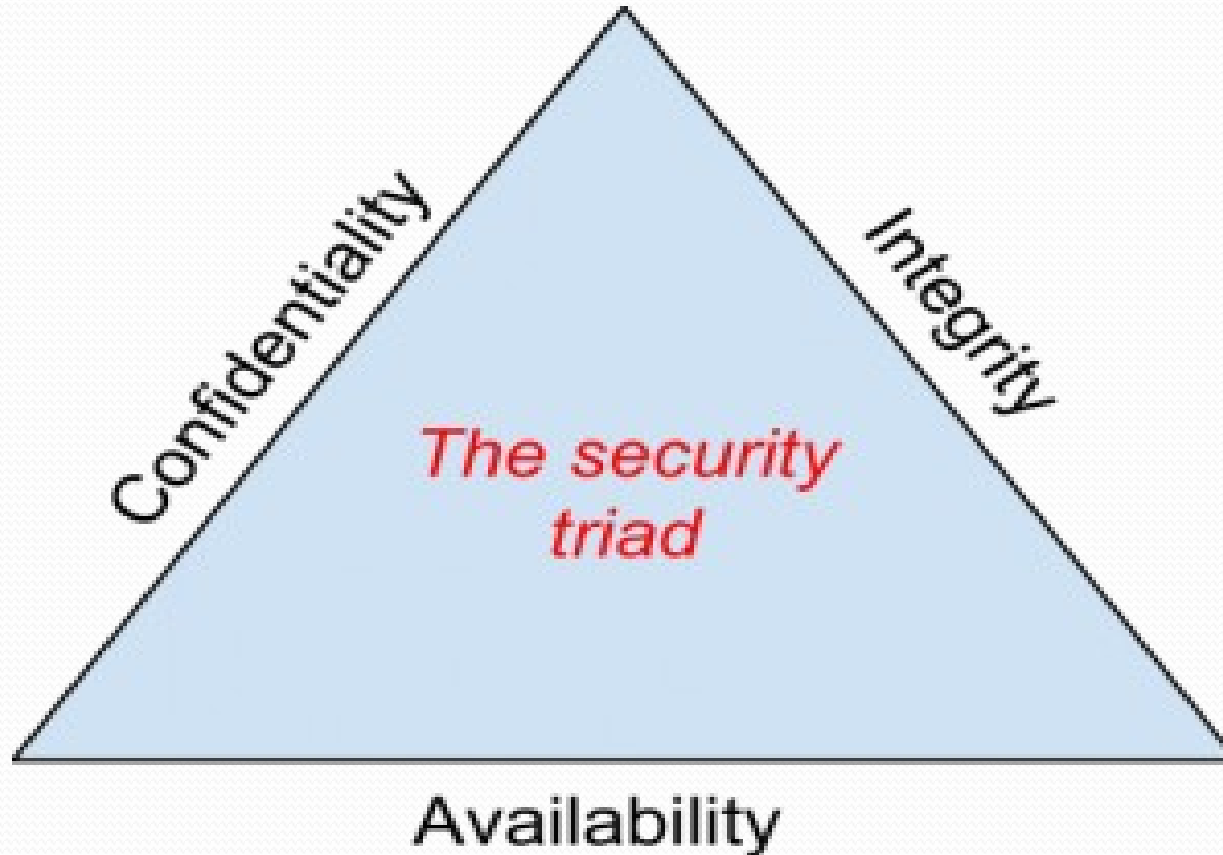
CHAPTER- SIX

ETHICAL AND SECURITY ISSUES

INFORMATION SYSTEMS SECURITY

- As computers and other digital devices have become essential to business and commerce, they have also increasingly become a target for attacks.
- In order for a company or an individual to use a computing device with confidence, they must first be assured that the device is not compromised in any way and that all communications will be secure.

The Information Security Triad: Confidentiality, Integrity, Availability (CIA)



1. Confidentiality

- When protecting information, we want to be able to restrict access to those who are allowed to see it; everyone else should be disallowed from learning anything about its contents.
- This is the essence of **confidentiality**.
- For example, federal law requires that universities restrict access to private student information. The university must be sure that only those who are authorized have access to view the grade records.

2. Integrity

- Integrity is the assurance that the **information being accessed has not been altered (changed)** and truly represents **what is intended**.
- Information integrity means information truly represents its **intended meaning**.
- Information can lose its integrity through malicious intent, such as when someone who is not authorized makes a change to intentionally misrepresent something.

- 
- An example of this would be when a hacker is hired to go into the university's system and change a grade.
 - Integrity can also be lost unintentionally, such as when a computer power surge corrupts a file or someone authorized to make a change accidentally deletes a file or enters incorrect information.

3. Availability

- *Availability* means that information can be accessed and modified by anyone authorized to do so in an appropriate timeframe.
- Companies such as Amazon.com will require their servers to be available twenty-four hours a day, seven days a week. Other companies may not suffer if their web servers are down for a few minutes once in a while.

Tools for Information Security

- In order to ensure the confidentiality, integrity, and availability of information, organizations can choose from a **variety of tools**.
- Each of these tools can be utilized as part of an overall information-security policy. These tools are discussed in the following sections:

1. Authentication

- The most common way to identify someone is through their **physical appearance**, but how do we identify someone sitting behind a computer screen or at the ATM?
- Tools for authentication are used to ensure that the person accessing the information is, indeed, who they present themselves to be.
- Authentication can be accomplished by identifying someone through one or more of three factors: **something they know**, **something they have**, or **something they are**.

- For example, the most common form of authentication today is the **user ID and password**.
- In this case, the authentication is done by confirming something that the user knows (their ID and password).
- But this form of authentication is easy to compromise and stronger forms of authentication are sometimes needed.
- Identifying someone only by something they have, such as a key or a card, can also be problematic. When that identifying token is lost or stolen, the identity can be easily stolen.

- 
- The final factor, something you are, is much harder to compromise.
 - This factor identifies a user through the use of a physical characteristic, such as an eye-scan or fingerprint.
 - Identifying someone through their physical characteristics is called *biometrics*.

2. Access Control

- Once a user has been authenticated, the next step is to ensure that they **can only access the information** resources that are appropriate.
- This is done through the use of access control.
- Access control determines which users are authorized to read, modify, add, and/or delete information.

3. Encryption

- Many times, an organization needs to transmit information over the Internet or transfer it on external media such as a CD or flash drive. In these cases, even with proper authentication and access control, it is possible for an unauthorized person to get access to the data.
- *Encryption is a process of encoding data upon its transmission or storage so that only authorized individuals can read it.*
- This encoding is accomplished by a computer program, which encodes the plain text that needs to be transmitted; then the recipient receives the cipher text and decodes it (decryption).

Password Security

- Why is using just a simple user ID/password not considered a secure method of authentication?
- It turns out that this single-factor authentication is extremely easy to compromise.
- Good password policies must be put in place in order to ensure that passwords cannot be compromised.
- Below are some of the more common policies that organizations should put in place.

- *Require complex passwords:* One reason passwords are compromised is that they can be easily guessed.
- A recent study found that the top three passwords people used in 2012 were *password*, *123456* and *12345678*.
- A password should not be simple, or a word that can be found in a dictionary.
- One of the first things a hacker will do is try to crack a password by testing every term in the dictionary! Instead, a good password policy is one that requires the use of a minimum of *eight characters*, and at least *one upper-case* letter, *one special character*, and *one number*.

- *Change Passwords Regularly.* It is essential that users change their passwords on a regular basis.
- Users should change their passwords every **sixty** to **ninety** days, ensuring that any passwords that might have been stolen or guessed will not be able to be used against the company.

Principles of Technology Ethics

- a. Proportionality: The good achieved by the technology must outweigh (greater than) a harm or risk.
- b. Informed consent: Those affected by the technology should understand and accept the risks.
- c. Justice: Benefits and burdens of the technology should be distributed fairly.
- d. Minimized Risk: Even if judged acceptable by the other three guidelines, the technology must be implemented so as to avoid all unnecessary risk.

What is a Virus?

- ❖ It is self-replicating (copying themselves) programs which cannot exist without a host.
- ❖ These programs can be relatively harmless, or can completely incapacitate (prevent from functioning in a normal way) your computer.
- ❖ The damage done to your computer is called the **payload**, and can range from a harmless message or image being displayed to destroying files and reformatting the hard drive of your computer.

Protecting Your Computer from Viruses

Don'ts

- I. Never use storage media from an untrustworthy source
- II. Never download files from a site or person that you do not trust
- III. Never open an email attachment from a person you do not know
- IV. Never open an email attachment that looks unusual or suspicious

Do's

- ✓ Disable preview screens when using email
- ✓ Scan storage media (e.g., USB drives) before using them
- ✓ Use a real-time virus scanner or frequently check your system with an online virus scanner
- ✓ When using a real-time virus scanner, download virus updates every week
- ✓ Backup important files often
- ✓ Use personal firewall (network designed to block unauthorized access)software to prevent unauthorized Internet access to and from your computer

Thank you !

